

Vulnerability Assessment and Penetration Testing Report

PwnKit Local Privilege Escalation Validation

CVE-2021-4034 - pkexec / PolicyKit

Prepared By: Ayaan Raza

Role: EthicalHacking Intern

Prepared For: SecureDevLabs

Assessment Type: VAPT Practical Assessment

Target Environment: Ubuntu 20.04 KVM/libvirt Virtual Machine

Assessment Date: 15 May 2026

Report Version: 1.0

Classification: Confidential - For internship evaluation and authorized assessment only

Authorization Statement: This assessment was performed in a controlled lab environment created for an authorized internship task. No third-party systems, public infrastructure, or unauthorized assets were tested.

1. Executive Summary

During the assessment, a local privilege escalation vulnerability was identified and validated on the target Ubuntu 20.04 virtual machine. The affected component was pkexec, which is part of the PolicyKit framework. The vulnerability is tracked as CVE-2021-4034 and is commonly known as PwnKit.

The vulnerability allowed a low-privileged local user to escalate privileges to root. Successful exploitation demonstrated complete administrative control over the target system.

This issue is rated Critical because root-level access allows full system compromise, including access to sensitive files, modification of system configuration, persistence setup, and disabling of security controls. Remediation requires updating the affected PolicyKit packages to a patched version and verifying that exploitation is no longer possible.

2. Scope of Assessment

The assessment was performed on a controlled Ubuntu 20.04 virtual machine deployed in a local KVM/libvirt lab environment. The scope was limited to identifying, analyzing, and validating the PwnKit local privilege escalation vulnerability affecting pkexec/PolicyKit.

The assessment did not include external systems, public infrastructure, production assets, password attacks, persistence, data exfiltration, or lateral movement.

3. Target Environment

Target Operating System: Ubuntu 20.04

Virtualization Platform: KVM/libvirt

Target User: ubuntu

Affected Component: policykit-1 / pkexec

Vulnerable Package Version: 0.105-26ubuntu1

Patched Comparison Version: 0.105-26ubuntu1.3 or later

Network: Local lab network

```
ubuntu@ubuntu:~$ hostnamectl
  Static hostname: ubuntu
        Icon name: computer-vm
        Chassis: vm
        Machine ID: 96a90a6ed3ae422984b2cf5a2049475e
        Boot ID: cb50b5998aa14c9faa538e97b640d14e
  Virtualization: kvm
  Operating System: Ubuntu 20.04.1 LTS
        Kernel: Linux 5.4.0-42-generic
        Architecture: x86_64
ubuntu@ubuntu:~$
```

```

ubuntu@ubuntu:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: enp1s0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group
default qlen 1000
    link/ether 52:54:00:07:f7:dd brd ff:ff:ff:ff:ff:ff
    inet 192.168.100.176/24 brd 192.168.100.255 scope global dynamic enp1s0
        valid_lft 3449sec preferred_lft 3449sec
    inet6 fe80::5054:ff:fe07:f7dd/64 scope link
        valid_lft forever preferred_lft forever

```

4. Methodology

The assessment followed a standard VAPT workflow:

1. **Information Gathering:** The target operating system, package versions, and pkexec binary permissions were reviewed.
2. **Vulnerability Identification:** The installed PolicyKit version was compared against known vulnerable versions of CVE-2021-4034.
3. **Vulnerability Analysis:** The pkexec binary was confirmed to have SUID-root permissions, which is important because pkexec runs with elevated privileges.
4. **Exploitation / Validation:** A controlled exploit was executed from a low-privileged user account to validate whether privilege escalation was possible.
5. **Impact Assessment:** The post-exploitation user context was checked to confirm whether root privileges were obtained.
6. **Remediation Planning:** Patch-based remediation and verification steps were identified.

5. Vulnerability Identification

The target was reviewed for the presence of a vulnerable PolicyKit package. The installed package version was identified as policykit-1 0.105-26ubuntu1. This version was selected for validation because it is affected by CVE-2021-4034 in the lab environment.

```

ubuntu@ubuntu:~$ pkexec --version
pkexec version 0.105
ubuntu@ubuntu:~$ dpkg -l | grep -E 'policykit|polkit'
ii  libpolkit-agent-1-0:amd64      0.105-26ubuntu1      amd64
    PolicyKit Authentication Agent API
ii  libpolkit-gobject-1-0:amd64  0.105-26ubuntu1      amd64
    PolicyKit Authorization API
ii  policykit-1                   0.105-26ubuntu1      amd64
    framework for managing administrative policies and privileges

```

The pkexec binary was also checked for SUID-root permissions. The SUID bit is relevant because it allows the binary to execute with the privileges of the file owner, which is root.

```
ubuntu@ubuntu:~$ ls -l /usr/bin/pkexec
-rwsr-xr-x 1 root root 31032 Aug 16 2019 /usr/bin/pkexec
```

6. Vulnerability Analysis

CVE-2021-4034 is a local privilege escalation vulnerability in pkexec. The issue is related to incorrect handling of calling parameters and environment variables. Under vulnerable conditions, an attacker with local user access can cause pkexec to load attacker-controlled components and execute code with root privileges.

The vulnerability requires local access to the system. It is still considered critical because any attacker who already has a low-privileged account or shell on the system may escalate to root and fully compromise the host.

In this assessment, the vulnerable conditions were confirmed by the package version, the presence of the SUID bit on /usr/bin/pkexec, and successful exploitation from the low-privileged ubuntu user account.

7. Exploitation / Validation

The exploitation phase was performed only to validate the vulnerability in the controlled lab environment. The exploit components were prepared outside the target VM and then transferred to the target. This approach reflects a realistic scenario where compilers or development tools may not be available on the target system.

Before exploitation, the current user context was checked to confirm that the tester was operating as a low-privileged user.

```
ubuntu@ubuntu:~$ id
uid=1000(ubuntu) gid=1000(ubuntu) groups=1000(ubuntu),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),117(netdev),118(lxd)
ubuntu@ubuntu:~$
```

The exploit was then executed to validate whether the vulnerable pkexec behavior could be triggered.

After exploitation, the user context was checked again. Successful exploitation was confirmed when the session showed root privileges.

```
ubuntu@ubuntu:~$ ./exploitpwn
# id
uid=0(root) gid=0(root) groups=0(root),4(adm),20(dialout),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),117(netdev),118(lxd),1000(ubuntu)
#
```

8. Impact Assessment

Successful exploitation allows a local attacker to gain root privileges on the affected system. With root access, an attacker can read or modify sensitive files, create or modify users, install persistence mechanisms, disable security controls, alter logs, and fully control the operating system.

The impact is rated Critical because privilege escalation from a normal user to root removes the main security boundary between a compromised low-privileged account and full system compromise.

9. Risk Rating

Severity: Critical

Attack Vector: Local

Privileges Required: Low local user access

User Interaction: None after local execution

Confidentiality Impact: High

Integrity Impact: High

Availability Impact: High

Overall Risk: Critical due to confirmed root-level privilege escalation

10. Remediation

The recommended remediation is to update PolicyKit to a patched version provided by the operating system vendor. For Ubuntu 20.04, the vulnerable package observed in the lab was policykit-1 0.105-26ubuntu1. A patched comparison version observed during testing was 0.105-26ubuntu1.3.

Recommended actions:

- Update policykit-1, libpolkit-agent-1-0, and libpolkit-gobject-1-0 using the system package manager.
- Verify the installed package version after patching.
- Re-test pkexec to confirm the exploit no longer succeeds.
- Maintain regular patch management for Linux systems and cloud/server images.
- Monitor systems for suspicious local privilege escalation behavior.

11. Conclusion

The assessment confirmed that the target Ubuntu 20.04 lab VM was vulnerable to CVE-2021-4034, commonly known as PwnKit. The vulnerable PolicyKit package and SUID-root pkexec binary created conditions that allowed a low-privileged user to escalate to root.

The vulnerability was successfully validated in a controlled environment, and the impact was confirmed through root-level user context after exploitation. The issue should be remediated by applying the vendor-provided PolicyKit security updates and retesting to confirm that privilege escalation is no longer possible.

12. Appendix: Evidence Checklist

Use this checklist while inserting screenshots:

- Screenshot 1 - Operating system and target environment details.
- Screenshot 2 - Target IP/network details, if required by the assignment.
- Screenshot 3 - Vulnerable PolicyKit package version/pkexec SUID-root permission.
- Screenshot 4 - Low-privileged user context before exploitation.
- Screenshot 5 - Exploit execution.
- Screenshot 6 - Root user context after exploitation.

13. References

- Qualys Research - PwnKit Local Privilege Escalation:
<https://blog.qualys.com/vulnerabilities-threat-research/2022/01/25/pwnkit-local-privilege-escalation-vulnerability-discovered-in-polkits-pkexec-cve-2021-4034>